

AVANCE DE PROYECTO INTEGRADOR

Planes de Respuesta a Incidentes

Alumno: Luis Alberto Vargas Gonzalez.

Maestría en Ciberseguridad.

I. Introducción al plan continuidad de negocio

El presente **Plan de Continuidad del Negocio (BCP)** tiene como objetivo principal garantizar que la empresa automotriz mantenga sus operaciones críticas ante cualquier interrupción mayor, protegiendo la integridad de sus **35,000 empleados** y su valiosa propiedad intelectual. Este plan maestro se integra por dos subplanes fundamentales que trabajan en conjunto:

1º Plan de Recuperación de Desastres (DRP): Es el brazo técnico del BCP. Se enfoca exclusivamente en la restauración de la infraestructura de TI, incluyendo la recuperación de los **mainframes IBM**, los servidores de bases de datos (**Oracle, DB2, SQL Server**) y la conectividad de la red **Cisco**. Su meta es cumplir con los tiempos de recuperación (RTO) definidos para los sistemas que sostienen la manufactura.

2º Plan de Recuperación del Negocio (BRP): Se centra en los procesos humanos y operativos. Define cómo deben actuar los departamentos (como el centro de diseño en Múnich o las plantas ensambladoras) para seguir funcionando mientras la tecnología es restaurada, incluyendo protocolos de reubicación de personal y comunicación de crisis.



II. Análisis y valoración de riesgos

Riesgo Identificado	Valoración (Impacto/Prob.)	Consecuencias Técnicas y de Negocio
1. Actividad Sísmica en Múnich.	Crítico / Alta	Pérdida de vidas humanas, destrucción física del centro de diseño y pérdida total de la propiedad intelectual premium no respaldada.
2. Explotación de BD sin parches (Oracle/DB2).	Alto / Alta	Robo de secretos industriales de manufactura y alteración maliciosa de registros de producción.
3. Falla de Infraestructura Cisco Obsoleta.	Alto / Media	Interrupción total de la conectividad entre plantas, detención de la cadena de suministro y parálisis operativa.
4. Exfiltración por "Full Access" Generalizado.	Medio / Alta	Fuga de información confidencial facilitada por empleados con privilegios excesivos, dañando la ventaja competitiva.
5. Ransomware vía Software No Autorizado.	Crítico / Media	Cifrado masivo de estaciones de trabajo y servidores, detención de actividades y posible extorsión económica.



Planes, Programas y Procedimientos

Riesgo Identificado	Valoración (Impacto/Prob.)	Consecuencias Técnicas y de Negocio
6. Pérdida de Datos por Respaldos Insuficientes.	Crítico / Alta	Incapacidad de restaurar la operación tras un incidente, resultando en la pérdida del 75% de la información histórica.
7. Intrusión Física por Fallo de Monitoreo.	Medio / Media	Robo de prototipos físicos en laboratorios y manipulación directa de hardware crítico por personas ajenas.
8. Downtime por Mantenimiento Prolongado.	Bajo / Alta	Pérdida de productividad planificada y retrasos significativos en los ciclos de entrega de vehículos premium.
9. Fuga de Datos vía Shadow IT (AnyDesk).	Alto / Alta	Apertura de "puertas traseras" que eluden el perímetro de seguridad, permitiendo el robo de datos sin dejar rastro en el SIEM.
10. Denegación de Servicio (DoS) en Mainframes	Alto / Media	Inoperatividad de los sistemas centrales que controlan los procesos robotizados de las plantas ensambladoras.



III. Medidas preventivas

1. Establecimiento de un Sitio de Recuperación Alterno (Hot Site): Implementar una sede espejo fuera de la zona sísmica de Múnich para asegurar que los ingenieros de diseño puedan retomar actividades de inmediato si el edificio principal sufre daños estructurales.

2. Ciclo de Vida de Activos y "Hardware Refresh": Programar la sustitución obligatoria del equipo Cisco cada 3 o 4 años, asegurando que la infraestructura de red siempre cuente con soporte del fabricante y actualizaciones de firmware vigentes.

3. Implementación de un Programa de Gestión de Vulnerabilidades: Ejecutar un calendario de parchado mensual para los motores de base de datos Oracle, DB2 y SQL Server, utilizando técnicas de "virtual patching" para proteger sistemas críticos mientras se programan las ventanas de mantenimiento.

4. Adopción del Principio de Menor Privilegio (RBAC): Configurar una matriz de control de acceso basada en roles donde el "Full Access" sea eliminado y cada uno de los **35,000 empleados** solo tenga permisos para los datos estrictamente necesarios para su función.

5. Despliegue de EDR (Endpoint Detection and Response): Sustituir los antivirus gratuitos por una solución empresarial de detección y respuesta que bloquee automáticamente la instalación de software no autorizado como *Call of Duty* o *AnyDesk*.



6. Automatización de la Estrategia de Respaldo 3-2-1: Incrementar la capacidad de almacenamiento para garantizar que el 100% de la información crítica sea respaldada, manteniendo al menos una copia cifrada en una región de nube distinta a la ubicación física de las plantas.

7. Fortalecimiento de la Seguridad Perimetral Física: Reparar el sistema de cámaras de circuito cerrado (CCTV) e implementar controles biométricos de acceso en laboratorios para evitar intrusiones físicas no autorizadas.

8. Configuración de Alta Disponibilidad (HA): Implementar clústeres redundantes para los servicios críticos y mainframes, permitiendo que un nodo asuma la carga si otro falla, reduciendo las ventanas de mantenimiento de 2 días a solo minutos.

9. Filtrado de Contenido Web y Whitelisting: Implementar políticas de control en el firewall para permitir únicamente el tráfico hacia sitios y aplicaciones de negocio, mitigando el riesgo de descargas maliciosas desde internet.

10. Sistemas de Prevención de Intrusiones (IPS) para Mainframes: Colocar sensores de red especializados frente a los servidores Unix e IBM que detecten y bloqueen intentos de Denegación de Servicio (DoS) antes de que afecten la línea de producción



IV. Principales procesos identificados

Descripción	Costo	Riesgos	Impacto en caso de suspensión	Observaciones
Mainframe IBM z15 (Producción)	Alto	Medio	Alto	Controla el ensamble robotizado; su caída detiene la producción global.
Core de Red Cisco (Plantas y Múnich)	Alto	Alto	Alto	Equipo obsoleto de +5 años; si falla, se pierde la conexión entre sedes.
Servidores de BD (Oracle/DB2/SQL)	Medio	Alto	Alto	Almacenan diseños y datos de manufactura; vulnerables por falta de parches.
Laptops/Workstations de Diseño en Múnich.	Alto	Alto	Alto	Interrupción del ciclo de diseño de piezas premium; riesgo de pérdida total de IP (Propiedad intelectual) por falta de respaldos externos.
Unidades de almacenamiento para respaldos corporativos.	Alto	Alto	Alto	Capacidad actual insuficiente (25%); su falla implica pérdida total de IP y posibles demandas por incumplimiento de contratos.
Sistemas de Control Industrial (PLCs/Línea de Ensamble)	Alto	Medio	Alto	La suspensión detiene físicamente la manufactura de vehículos; riesgo de daños a maquinaria.
Directorio Activo / Servicio de Identidad (IAM)	Medio	Alto	Alto	Si se suspende, nadie puede loguearse; facilita el "Full Access" actual si no se controla.
Sistemas de Seguridad Física (CCTV y Gafetes)	Medio	Alto	Medio	Inoperantes actualmente; su suspensión permite el robo de prototipos físicos.



V. Respaldo y recuperación de información

Tipo	Clasificación	Consecuencias	Modo de recuperación
Ataque Ransomware Masivo	Crítico	Cifrado de bases de datos de manufactura y pérdida de acceso a diseños en Múnich.	1. Aislamiento de red y segmentación vía ACLs. 2. Activación de TPM y reseteo de fábrica con cambio de SO. 3. Restauración de BD desde respaldos limpios validados.
Incendio	Grave	Pérdida total de servidores físicos y estaciones de trabajo en planta.	Adquisición de hardware nuevo y restauración desde la copia de seguridad en la nube (fuera de sitio).
Temblor (Múnich)	Grave	Daño estructural y pérdida de diseños premium no respaldados localmente.	Activación del Hot Site en zona segura. Recuperación de diseños mediante el "Cold Backup" de workstations no dañadas y sincronización con nube.
Robo de Equipo	Bajo	Exfiltración de IP y pérdida de activos físicos.	Bloqueo remoto de cuentas (IAM), revocación de certificados y restauración de la imagen del sistema en equipo nuevo.
Epidemia/Pandemia	Alto	Inoperatividad presencial de los 35,000 empleados.	Despliegue masivo de túneles VPN cifrados y virtualización de aplicaciones para permitir el diseño y administración remota segura.
Toma Hostil / Terrorismo	Crítico	Riesgo de pérdida de vidas, robo de IP física y parálisis total.	Activación inmediata del Comité de Crisis. Notificación a autoridades. Bloqueo remoto de sistemas críticos. Reubicación de funciones al Hot Site.
Interrupción de Suministro Eléctrico	Alto	Paro total de líneas de producción, riesgo de corrupción en bases de datos y pérdida de visibilidad en monitoreo de seguridad.	Activación de UPS para cierre ordenado de sistemas críticos. Uso de plantas de emergencia (generadores). Transferencia de cargas administrativas al Hot Site o centro redundante.

